

Conversating with our web app

94

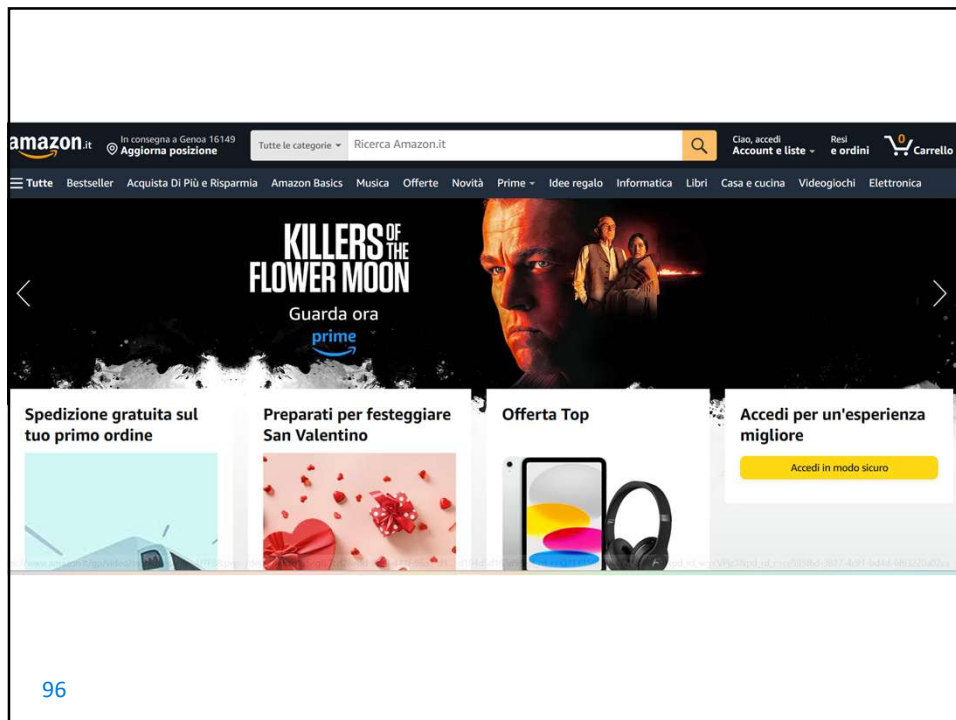
Navigation Session

- Interactions with a web app can be thought as a conversation. Such a conversation is called:

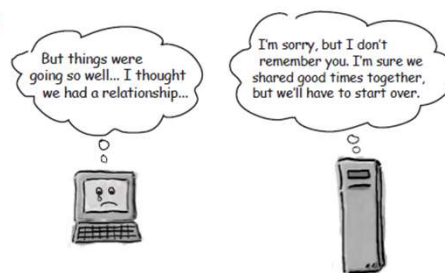
navigation session

i.e. a sequence of http requests logically correlated coming from the same client and going to the same server that replies with responses

95



HTTP is stateless
 How can we keep track of who is who, and
 which state of the process s/he is at?



Picture from: Head First – Servlets and JSP, 2008

Three solutions

- HTML hidden field
- Cookies
- Session

```
<form>
  <div>
    <label for="title">Post title:</label>
    <input type="text" id="title" name="title" value="My post" />
  </div>
  <div>
    <label for="content">Post content:</label>
    <input type="text" id="content" name="content" value="Hello" />
  </div>
  <div>
    <button type="submit">Update post:</button>
  </div>
  <input type="hidden" id="my_hidden" name="my_hidden" value="Nobody can see me" />
</form>
```



Session

98

HTML hidden field: how does it work?

- Information related to the state is passed as parameter though the Controller to give the illusion of persistence

Welcome to the Simple Calculator

Enter your name:

```
<form action="/greet_data" method="post">
  <label for="name">Enter your name:</label>
  <input type="text" id="name" name="name" required>
  <button type="submit">Submit</button>
</form>
```

99

esempio13bis

HTML hidden field: how does it work?

Welcome, Giovanna!

Operand 1:

Operand 2:

Operator:

```
@PostMapping("/greet_data")
public String welcome
(@RequestParam("name") String name, Model model)
{
    model.addAttribute("name", name);
    return "greet_data";
}
```

- OK, we know how to do that! But at the end we have:

Thank you for using the Simple Calculator!

Goodbye, Giovanna!

How can we do it?

100

HTML hidden field: how does it work?

- We propagate the name using a hidden HTML input field

greet_data.html

```
<form action="/compute" method="post">

    <input type="hidden" name="name" th:value="${name}">

    <label for="operand1">Operand 1:</label>
    <input type="number" id="operand1" name="operand1" required><br><br>

    <label for="operand2">Operand 2:</label>
    <input type="number" id="operand2" name="operand2" required><br><br>
    ...
</form>
```

In Controller's methods

```
@PostMapping("/compute")
public String compute(@RequestParam("operand1") double operand1,
    @RequestParam("operand2") double operand2,
    @RequestParam("operator") String operator,
    @RequestParam("name") String name,
    Model model) {
    ...
    model.addAttribute("name", name);
    return "results";}
```

100

Cookies: a Chinese origin...



102

Cookies: what they are

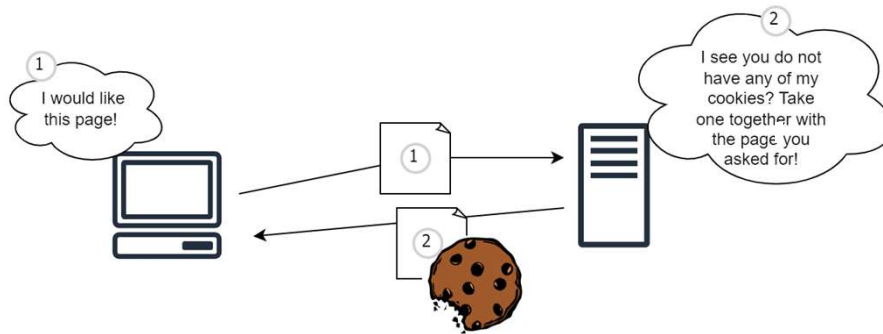
A Cookie is a small amount of information sent by a server to a Web browser, saved by the browser, and later sent back to the server

A cookie's value *uniquely* identifies a client, so cookies are commonly used to manage interactions with the Web app

A cookie has a name, a single value, and optional attributes such as a comment, path and domain qualifiers, a maximum age, and a version number

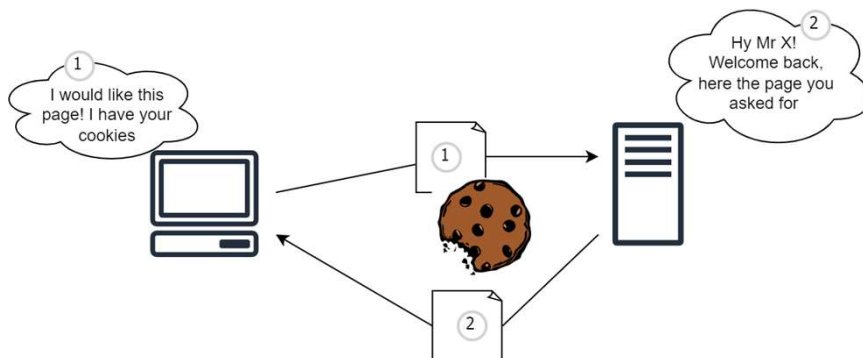
103

How do cookies work?



10
4

How do cookies work?



The browser is expected to support **20** cookies for each Web server, **300** cookies total, and may limit cookie size to **4 KB** each

105

Let's check cookies' table in Chrome!

106

Cookies in Spring

- The **first time** a client and a web server meet:
 - The server prepares a new cookie and sends it to the browser by adding them to the HTTP response headers
 - This is done through a **ResponseCookie** object that builds the cookie and a **ResponseEntity** object that allows you to specify the response body, status and header on a HTTP response
- ResponseCookie is a Spring Class to build cookies and set its parameters
- ResponseEntity<T> is a Spring class representing a whole HTTP response, not only the body. T is the body type (e.g. String or Void)

107

Cookies in Spring

- Next times the client meets the same web server:
 - The browser returns cookies to the server by adding fields to HTTP request headers
 - The server reads the cookies that come back using a parameter of the invoked method annotated with `@CookieValue`
- `@CookieValue` only works in Controller's methods. It reads a specific cookie's value in a HTTP request. Using `required = false`: if the specific cookies is not there, the variable for the cookie value is set to null.

108

Cookies in action!

esempio14

Cookies: legal aspects

110

Italian regulations

Individuazione delle modalità semplificate per l'informativa e l'acquisizione del consenso per l'uso dei cookie – 8/05/2014

- <http://garanteprivacy.it/web/guest/home/docweb/-/docweb-display/docweb/3118884>
- <https://www.garanteprivacy.it/home/doveri>
- https://it.wikipedia.org/wiki/Regolamento_generale_sulla_protezione_dei_dati

111

Italian regulations: technical cookies

Cookie tecnici:

quelli utilizzati al solo fine di *"effettuare la trasmissione di una comunicazione su una rete di comunicazione elettronica, o nella misura strettamente necessaria al fornitore di un servizio della società dell'informazione esplicitamente richiesto dall'abbonato o dall'utente a erogare tale servizio"* (cfr. art. 122, comma 1, del Codice).

They are strictly needed to run services!

112

Italian regulations: technical cookies

Essi non vengono utilizzati per scopi ulteriori e sono normalmente installati direttamente dal titolare o gestore del sito web.

Possono essere suddivisi in:

- **cookie di navigazione o di sessione**, che garantiscono la normale navigazione e fruizione del sito;
- **cookie analytics**, assimilati ai cookie tecnici laddove utilizzati direttamente dal gestore del sito per raccogliere informazioni, in forma aggregata, sul numero degli utenti e su come questi visitano il sito stesso;

113

Italian regulations: technical cookies

- **cookie di funzionalità**, che permettono all'utente la navigazione in funzione di una serie di criteri selezionati (ad esempio, la lingua, i prodotti selezionati per l'acquisto) al fine di migliorare il servizio reso allo stesso.

Per l'installazione di tali cookie non è richiesto il preventivo consenso degli utenti, mentre resta fermo l'obbligo di dare l'informativa ai sensi dell'art. 13 del Codice, che il gestore del sito, qualora utilizzi soltanto tali dispositivi, potrà fornire con le modalità che ritiene più idonee.

114

Italian regulations: profiling cookies

Cookie di profilazione:

sono quelli volti a creare profili relativi all'utente e vengono utilizzati al fine di inviare messaggi pubblicitari in linea con le preferenze manifestate dallo stesso nell'ambito della navigazione in rete.

In ragione della particolare invasività che tali dispositivi possono avere nell'ambito della sfera privata degli utenti, la normativa europea e italiana prevede che l'utente debba essere adeguatamente informato sull'uso degli stessi ed esprimere così il proprio valido consenso.

115

Italian regulations

Soggetti coinvolti: editori e "terze parti"

Un ulteriore elemento da considerare, ai fini della corretta definizione della materia in esame, è quello soggettivo. Occorre, cioè, tenere conto del differente soggetto che installa i cookie sul terminale dell'utente, a seconda che si tratti dello stesso gestore del sito che l'utente sta visitando (che può essere sinteticamente indicato come "editore") o di un sito diverso che installa cookie per il tramite del primo (c.d. "terze parti").

116

Italian regulations: last remarks

Nel momento in cui l'utente accede a un sito web, **deve essergli presentata una prima informativa "breve", contenuta in un banner a comparsa immediata sulla home page** (o altra pagina tramite la quale l'utente può accedere al sito), **integrata da un'informativa "estesa"**, alla quale si accede attraverso un link cliccabile dall'utente.

117

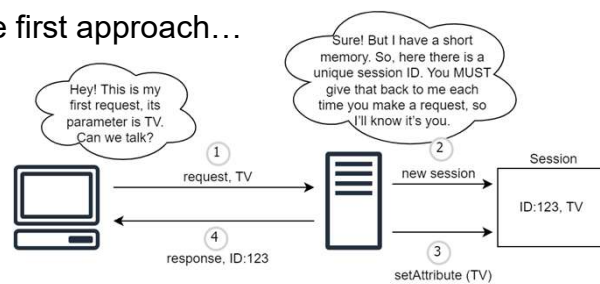
Sessions

- Sessions are higher level mechanisms than cookies
- For each conversation, the web server generates a unique ID and a data structure in memory which are associated both with that conversation
- The unique ID is exchanged with the client during its conversation with the web server
- The data structure is used to keep track of the state (i.e., it contains all the information describing the state)

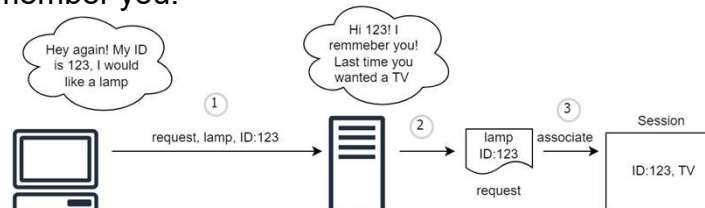
118

Can we talk?

- The first approach...



- I remember you!



119

How does the unique ID is exchanged?

- In all the responses to the client, the web server automatically and transparently adds a cookie with the session ID
- This cookie is called **session cookie**:
 - It has not expiration time
 - It dies at the end of the session
- Through the ID, the web server retrieves the data structure containing the information associated to that session

120